- imposer une **complexité du mot de passe** en fonction des cas d'usage :
  - **par défaut, entropie**[14] (imprédictibilité théorique) **minimale de 80 bits** (ex. : 12 caractères minimum comportant des majuscules, des minuscules, des chiffres et des caractères spéciaux ; 14 caractères minimum comportant des majuscules, des minuscules et des chiffres, sans caractère spécial obligatoire) ;
  - entropie de 50 bits (ex. : 8 caractères minimum de 3 types différents ; 16 chiffres) dans le cas où des mesures complémentaires sont en place (restriction de l'accès au compte telle qu'une temporisation de l'accès après plusieurs échecs, la mise en place de « Captcha » ou le blocage du compte après 10 échecs) ;
  - entropie de 13 bits (ex. : 4 chiffres) dans le cas d'un matériel détenu par l'utilisateur (ex. : carte SIM, dispositif contenant un certificat) avec blocage au bout de 3 échecs.

- **Accompagner les utilisateurs pour le choix d'un mot de passe robuste :**
  - en sensibilisant sur les **moyens mnémotechniques**[15] ;
  - en incitant à l'utilisation de **gestionnaires de mots de passe**[16] et en formant à leur utilisation :
    - il permet d'enregistrer de façon sécurisée autant de mots de passe que nécessaire tout en n'exigeant la mémorisation que d'un seul mot de passe maître ;
    - le mot de passe maître doit par conséquent être particulièrement robuste ;
    - une attention particulière doit être apportée au choix de la solution.
- **Communiquer sur les pratiques interdites**[17] (ex. : communiquer son mot de passe à une autre personne, utiliser un mot de passe pouvant être déduit du contexte dans lequel il est utilisé, enregistrer les mots de passe dans un navigateur sans mot de passe maître). **Un mot de passe respectant l'entropie exigée peut toujours être facilement utilisé par un attaquant en cas de mauvaises pratiques**.

Ce qu'il ne faut pas faire

- Utiliser les mots de passe par défaut des équipements et logiciels.
- Conserver les mots de passe en clair et non une empreinte cryptographique.
- Utiliser, pour la génération de l'empreinte des mots de passe à stocker, une fonction cryptographique de hachage obsolète, telle que MD5 ou SHA-1 (voir la fiche n°21 - Chiffrement, hachage, signature), ou conçue en interne qui est, par conséquent, non reconnue ou éprouvée.
- Empêcher l'usage de la fonction « Coller » ou de l'auto-complétion dans les formulaires pour ne pas impacter l'utilisation d'un gestionnaire de mots de passe.

---

14 L'entropie, appliquée à un mot de passe, correspond à sa capacité de résistance à une attaque par force brute. À titre d'exemple, pour le code secret d'une carte bancaire, le nombre de combinaisons possibles est égal à 10 (chiffres possibles) à la puissance 4 (10^4). En binaire, pour obtenir un nombre de combinaisons équivalent, il faut utiliser 13 bits, car 2 (bits possibles) à la puissance 13 (2^{13}) vaut 8 192, ce qui est du même ordre de grandeur que 10^4. On parle alors d'une entropie de 13 bits.

15 « Générer un mot de passe solide », cnil.fr

16 « 5 arguments pour adopter le gestionnaire de mots de passe », cnil.fr

17 « Les conseils de la CNIL pour un bon mot de passe », cnil.fr